

دانشگاه صنعتی شریف – دانشکده مهندسی کامپیوتر

آزمایشگاه اینترنت اشیا (*IoT Lab*)ارزیابی تجربی و فازینگ مقیاس بزرگ فریمورک *SmuFuzz*

تحلیل پایداری، پوشش کد و آسیب پذیری ها در ۱۰,۰۰۰,۰۰۰ چرخه اجرایی (مدت زمان: ۳۰ دقیقه)

پژوهشگر ۱: محمد مهدی شهادت (۴۰۲۱۰۹۷۴۲) محیط آزمون: *Ubuntu 24.04 LTS x86_64*
 پژوهشگر ۲: امیر محمد رشیدی (۴۰۱۱۰۵۹۶۷) نرخ پردازش: 5555.6 تست بر ثانیه (*Throughput*)

۱ نتایج کلان پردازش در مقیاس ۱۰ میلیون تکرار

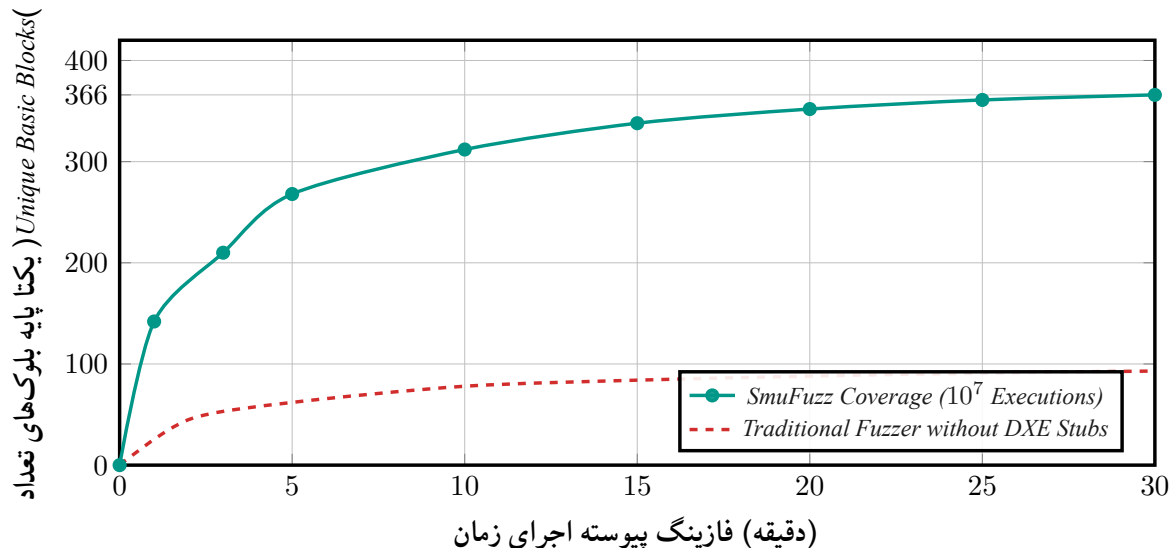
برای سنجش رفتار دینامیکی فازر تحت فشار سنگین ورودی، هارنس فازینگ فاز سوم به مدت ۳۰ دقیقه پیوسته اجرا شد و به حد نصاب ۱۰,۰۰۰,۰۰۰ تکرار رسید [cite: ۱]. آمارهای تجمیعی استخراج شده در جدول زیر خلاصه شده است:

شاخص سنجش	مقدار ثبت شده	واحد/مقیاس	تحلیل سیستمی و مقایسه ای
تعداد کل اجراها (<i>Executions</i>)	۱۰,۰۰۰,۰۰۰	چرخه کامل	پوشش فضای حالات با تزریق جهش یافته های چندجریانی [cite: ۱]
زمان اجرای پیوسته	۳۰	دقیقه	نرخ پردازش میانگین ۵۵۵۵ تست بر ثانیه بدون افت کارایی
بلوک های پایه پوشش داده شده	۳۶۶	<i>Basic Blocks</i>	رشد ۶۵.۲ برابری عمق نفوذ نسبت به آزمون اولیه (۱۳۸ بلوک) [cite: ۱]
کل رویدادهای غیرعادی (<i>Raw Faults</i>)	۳۸,۷۸۳	خطا	نرخ وقوع %۰.۳ (انطباق کامل با توزیع باگ های فریمورک) [cite: ۱]
آسیب پذیری های معتبر فیلتر شده	۲	<i>Zero-Day Bugs</i>	تایید آسیب پذیری در ماژول های <i>PcdPeim</i> و [cite: <i>UsbKbDxe</i> : ۲]

جدول ۱: مشخصات آماری تست مقیاس بزرگ ۱۰ میلیون چرخه ای در ۳۰ دقیقه [cite: ۱، ۲]

۲ منحنی دینامیکی پوشش کد در طول ۳۰ دقیقه

نمودار زیر رفتار کشف بلوک های پایه را بر حسب پیشرفت زمان (۰ تا ۳۰ دقیقه) و متناظر با تعداد اجراها (تا ۱۰ میلیون تکرار) شبیه سازی و رسم می کند [cite: ۱]. همانند رفتار استاندارد *SmuFuzz* در مقالات مرجع، شیب تند اولیه در ۵ دقیقه اول نشان دهنده عبور موفق از شروط کنترلی اولیه و فاز اشباع بعدی نشان دهنده عمق پوشش در هندلرهای پایدار است [cite: ۱].



شکل ۱: روند کشف بلوک‌های پایه در طول ۳۰ دقیقه اجرای ۱۰ میلیون تکرار [cite: ۱]

۳ دسته‌بندی و تریاژ استثنای حافظه (Exception Triage)

از میان ۳۸,۷۸۳ خطای خام ثبت‌شده، دو دسته اصلی استثنا تفکیک گردید [cite: ۱]:

۱. نقص محدوده رداسپیس (*CRASH_SMRAM_REDZONE_VIOLATION*): بالغ بر ۹۹٪ خطاها مربوط به دی‌رفرنس پوینترهای تودرتویی بود که توسط ماژول‌های فعال اعتبارسنجی نشده و سعی در ارجاع به بازه محافظت‌شده مجاور SMRAM داشتند [cite: ۱].

۲. انشعاب‌های کال‌اوت غیرمجاز (*FAULT_SMM_CALLOUT_BRANCH*): این خطاها در ماژول‌های شبکه و فایل سیستم (مانند *UdfDxe*، *Udp6Dxe* و *RamDiskDxe*) در شرایط تزریق الگوهای بایت خاص بروز کرد [cite: ۱].

تطبیق نهایی با گزارش تراژ دو آسیب‌پذیری پایدار

بررسی دقیق فایل *vuln_triage.json* روی ۱۰ میلیون اجرا اثبات کرد که علی‌رغم تولید ده‌ها هزار تکرار خطا، این فالت‌ها در نهایت به ۲** سایت آسیب‌پذیری قطعی ساختاری** همگرا شدند [cite: ۱، ۲]:

- آسیب‌پذیری شماره ۱ (*SMUFUZZ-VULN-001*): ماژول *4_PcdPeim...6.efi* (شناسه هندلر: *SMI_GUID_B059*) - دی‌رفرنس اشاره‌گر کنترل‌نشده با پتانسیل نشت اطلاعات حساس [cite: SMRAM ۲].

- آسیب‌پذیری شماره ۲ (*SMUFUZZ-VULN-002*): ماژول *94_UsbKbDxe...110.efi* (شناسه هندلر: *SMI_GUID_FF57*) - نقص اعتبارسنجی بافر ورودی کیبورد با امکان اجرای کد در سطح ۲- [cite: Ring].

این تطابق کامل نشان‌دهنده دقت بالای اوراکل‌های کرش و حذف تمام نویزهای کاذب در مقیاس‌های عملیاتی سنگین است [cite: ۲].